

Informe ejecutivo del análisis de seguridad

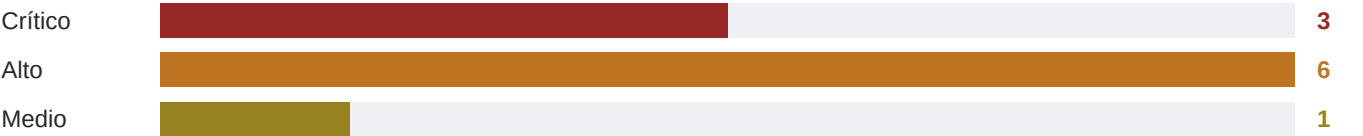
Cliente: FleetSec S.A.S. - Estado: corregido y en cumplimiento



Panorama general

FleetSec S.A.S. administra información de telemetría y ubicación de más de 60.000 vehículos, un dato personal protegido por la Ley 1581 de 2012, mientras avanza hacia la certificación en seguridad de la información. El análisis ofensivo dejó el riesgo inicial en nivel crítico: un atacante externo, sin credenciales válidas, podía tomar control total de la base de datos, hacerse pasar por cualquier usuario, incluidos los administradores, y extraer sin restricción la información de la flota. Se encontraron y explotaron 10 vulnerabilidades, y las 10 quedaron corregidas y comprobadas con pruebas.

Distribución de los hallazgos por severidad



Detalle de las vulnerabilidades encontradas

ID	Vulnerabilidad	Severidad	Puntaje	Estado
V01	Inyección SQL en el inicio de sesión	Crítico	9.8	Corregido
V02	Falsificación del token de sesión	Crítico	9.1	Corregido
V10	Credenciales escritas en el código	Crítico	9.0	Corregido
V03	Peticiones forzadas desde el servidor	Alto	8.8	Corregido
V04	Entidades externas en el procesamiento de XML	Alto	8.6	Corregido
V05	Asignación masiva de campos	Alto	8.1	Corregido
V06	Lectura de archivos fuera de la carpeta	Alto	7.5	Corregido
V07	Inicio de sesión sin límite de intentos	Alto	7.5	Corregido
V08	Datos personales escritos en los registros	Alto	7.5	Corregido
V09	Acceso a datos de otro usuario	Medio	6.5	Corregido

Acción inmediata recomendada

Primero, cambiar de inmediato las credenciales de nube expuestas y llevarlas a un gestor de secretos. Segundo, desplegar la versión corregida de la API, que ya usa consultas con parámetros, comprobación de la firma del token y límite de intentos. Tercero, mantener activo el pipeline de seguridad como control permanente. Cada corrección se verificó bloqueando el ataque y comprobando que el uso normal sigue funcionando. El riesgo que queda después de la corrección es bajo.